

Strategic Research Viability and Publication Assessment: Privilege Aggregation in MCP-Enabled Systems

Executive Go/No-Go Decision

A comprehensive strategic evaluation of the proposed research direction yields a definitive decision: **REVISE**.

The underlying subject matter—security vulnerabilities within Model Context Protocol (MCP)-enabled agentic systems—represents one of the most urgent, high-impact, and underexplored frontiers in contemporary cybersecurity.¹ The rapid transition of artificial intelligence from reactive text generation to autonomous, goal-seeking execution via standardized tool-calling protocols has fundamentally altered the threat landscape.³ This paradigm shift has created structural security gaps that current defense mechanisms, which rely heavily on prompt engineering and alignment, are largely failing to mitigate.⁴ The original research proposal astutely identifies two highly specific and advanced attack vectors that exploit this new architecture: privilege aggregation and transitive trust exploits.³

However, a strict and immediate "GO" cannot be recommended without critical revisions to the execution strategy. There is a fundamental mismatch between the original research plan's assumptions and the current operational constraints of an undergraduate researcher operating with zero funding, restricted consumer-grade hardware, and a mandate for journal-only publication. To ensure this project culminates in a peer-reviewed publication rather than languishing as an unfinished experiment, the framework must be rigorously restructured. The rationale for the **REVISE** decision is grounded in several critical factors that necessitate immediate adjustment. First, the publication venue realignment is paramount. The original proposal heavily emphasizes top-tier academic conferences and specialized physical workshops.³ These venues universally mandate in-person attendance, physical presentations, and costly registrations, which directly violate the stated constraints of the project. The entire research strategy, from the literature review to the empirical design, must be completely reoriented toward hybrid-model indexed journals that offer subscription-based publishing with no Article Processing Charges (APCs).⁵

Second, the hardware and cognitive limitations of the proposed experimental setup pose a severe risk to validity. The proposal assumes the local execution of low-parameter language models to simulate agentic reasoning.³ While financially feasible, models of this scale frequently struggle with complex, multi-step tool orchestration. If a local model fails to aggregate privileges simply because it lacks the cognitive capacity to parse JSON-RPC schemas properly, the empirical Attack Success Rate (ASR) will yield false negatives. This phenomenon would render the findings unpublishable in rigorous journals. The experimental design must be revised to account for these hardware-induced reasoning limitations, perhaps by establishing a strict baseline of functional competence before introducing adversarial elements.

Third, the original methodology suggests synthesizing custom evaluation datasets.³ Given a typical undergraduate timeline, building a bespoke dataset from scratch introduces severe completion risks and opens the research to accusations of evaluation bias during peer review. The methodology must be revised to integrate emerging, standardized benchmarks, such as the Open Agent Security Benchmark (OASB) and AgentDojo, to ensure rigorous, peer-review-ready empirical data without exhausting the project timeline.⁸ Finally, the scope and title of the project require significant refinement. The current title is overly broad, attempting to tackle two massive conceptual domains—privilege aggregation and transitive trust—simultaneously.³ For an undergraduate journal submission, narrowing the focus to a highly specific empirical evaluation of *either* privilege aggregation *or* transitive trust will yield a deeper, more publishable contribution. With these structural revisions applied, the core scientific inquiry is exceptionally strong. It requires no specialized hardware, avoids the saturated space of basic chatbot prompt injection, and targets a protocol that is currently experiencing rapid, widespread enterprise adoption.³

Research Novelty Analysis

A deep investigation into the current academic and industry literature indicates that the proposed research occupies a highly novel and currently unsaturated niche. However, the window for maintaining this novelty is closing rapidly as industry attention pivots aggressively toward agentic security. Establishing exactly where this research fits into the existing corpus of knowledge is essential for proving its academic worth.

The security of Large Language Models has historically focused on direct prompt injection designed to bypass content safety filters. As models evolved into agents capable of executing code, the literature shifted toward identifying the risks of external tool usage. Recent literature from early to mid-2026 highlights the state of the art in this domain. Huang et al. (2026) provided a systematic threat model of MCP implementations using STRIDE and DREAD frameworks.¹¹ Their work primarily focused on tool poisoning, where malicious instructions are embedded directly into a single tool's metadata, noting that this vector ranks first in OWASP's LLM Top 10.¹¹ Furthermore, Bhattarai and Vu (2026) established the theoretical framework of the "Lethal Trifecta"—untrusted inputs, privileged data access, and external action capabilities.⁴ They argued that because autoregressive models process code and data uniformly through the same attention mechanism, alignment alone is inherently insufficient.⁴ This necessitates deterministic architectural boundaries, a concept they formalized as the Trinity Defense Architecture.⁴

Industry research has also begun cataloging specific exploits. Palo Alto Networks' Unit 42 demonstrated that MCP's sampling primitives can be abused for resource theft, conversation hijacking, and covert tool invocation.¹⁴ Specifically, they showed how malicious servers could proactively request completions, draining client compute quotas, or append hidden instructions to trigger unauthorized file operations.¹⁴ Furthermore, Tenet Security and the Cloud Security Alliance documented "Agentjacking," a real-world attack class where AI coding agents connected via MCP are hijacked through poisoned Sentry error logs.² Because the agent retrieves these logs via an authorized, encrypted MCP connection, traditional Endpoint

Detection and Response (EDR) systems view the subsequent command execution as benign, allowing attackers to execute commands with the developer's local privileges.² Additionally, Maloyan and Namiot (2026) provided a comprehensive systematization of prompt injection attacks on agentic coding assistants, revealing that 85% of identified attacks successfully compromise major platforms.¹ They introduced a three-dimensional taxonomy spanning delivery vectors, attack modalities, and propagation behaviors, noting that protocol-level attacks remain underappreciated.¹

While the aforementioned literature firmly establishes that individual MCP tools can be poisoned and that remote data sources can hijack agents, there is a glaring scarcity of empirical academic research detailing dynamic multi-hop tool-chaining. Most current evaluations focus on a malicious server interacting directly with a client, or a single poisoned data source.² The proposed research investigates a more complex and insidious scenario: privilege aggregation. This occurs when an agent has access to multiple benign tools—for example, a benign reading tool, a benign database writing tool, and a benign network webhook tool. The research asks what happens when an indirect prompt injection forces the cognitive engine to aggregate these discrete, safe privileges to exfiltrate data.³ This specific intersection—evaluating the cognitive propensity of an LLM to chain tools maliciously under adversarial pressure within an isolated MCP environment—remains genuinely underexplored in peer-reviewed journals.

The novelty of this concept is exceptionally strong. Multi-tool privilege aggregation via indirect injection in MCP environments is highly cutting-edge, earning a concept novelty score of 9.0 out of 10. The methodological approach, utilizing quantitative metrics like Attack Success Rate (ASR) and Tool Invocation Deviation (TID) within localized MCP mock servers, is standard for the field but applied in a fresh context, earning an 8.0 out of 10. Consequently, the risk of rejection due to weak novelty is exceedingly low. Journals actively seek rigorous empirical studies on emerging protocols, especially those addressing structural flaws in enterprise AI deployments.¹⁸

However, the original title is overly descriptive and reads more like an overarching grant proposal than a focused empirical journal article. To enhance publishability, the title should immediately signal the empirical nature of the study and its specific focus.

Original Title Assessment	Suggested Refined Titles	Rationale for Change
Privilege Aggregation and Transitive Trust Exploits in Model Context Protocol (MCP)-Enabled Agentic AI Systems	<i>Evaluating Privilege Aggregation Vulnerabilities in MCP-Enabled AI Agents Under Indirect Prompt Injection</i>	Emphasizes the empirical evaluation aspect, which journals prefer over broad theoretical claims.
(Too broad, lacks methodological signaling)	<i>Transitive Trust Failures in Agentic Orchestration: A Security Analysis of the</i>	Narrows the focus exclusively to the mechanism of trust

	<i>Model Context Protocol</i>	propagation, making the scope manageable.
(Reads like a project rather than a formal academic contribution)	<i>Measuring the Lethal Trifecta: An Empirical Study of Multi-Tool Exploit Chaining in Open-Weight LLM Agents</i>	Connects directly to established academic theory (the Lethal Trifecta) while highlighting the use of open-weight models.

Feasibility Analysis

Evaluating whether an undergraduate student can realistically complete this rigorous research under strict constraints—no funding, a single local laptop, no paid APIs, and a short timeframe—requires a granular assessment of technical and methodological dependencies. The feasibility of this project hinges entirely on optimizing the compute strategy and standardizing the evaluation frameworks.

The most significant bottleneck in any AI research is compute availability. The proposal explicitly aims to bypass high API costs by executing open-weight models locally using frameworks like Ollama.³ Running models in the 8-billion parameter class (such as specific Llama-3 or Phi-3 variants) requires approximately 8GB to 12GB of Unified Memory or VRAM. This is standard on modern laptops, such as Apple M-series MacBooks or entry-level Windows machines with dedicated GPUs. Therefore, the financial viability is perfectly aligned with the constraints; zero financial outlay is necessary for hardware or inference.³

However, local inference of small models introduces a severe methodological blocker. Sub-10B parameter models often exhibit severe "tool-calling hallucinations" or fail to strictly adhere to the complex JSON-RPC schemas required by the Model Context Protocol.³ If the model fails to format a tool call correctly during a benign baseline test, it cannot be reliably evaluated for adversarial manipulation. To mitigate this, the research must deliberately utilize highly quantized, tool-optimized small models designed explicitly for function calling, rather than general-purpose chat models. Proving that the model can successfully execute benign tasks before introducing adversarial payloads is a critical prerequisite for the study's validity.

Dataset availability and evaluation complexity represent the second major feasibility hurdle. The original plan suggests generating custom injection payloads and mock tools.³ This approach is highly risky for an undergraduate. Reviewers frequently reject papers that rely on unvalidated, bespoke datasets, as they are prone to author bias and lack reproducibility. Fortunately, the recent release of standardized benchmarks drastically alters the feasibility landscape. The Open Agent Security Benchmark (OASB) provides 46 specific security controls and includes a CLI tool (HackMyAgent) capable of generating payloads for MCP exploitation, prompt injection, and agent-to-agent attacks.⁹ OASB's methodology involves clear requirements, maturity levels, and automated verification.²⁰ Similarly, the AgentDojo dynamic environment provides 97

realistic tasks and hundreds of security test cases designed specifically to test "Chaining & Planning" vulnerabilities in agents.⁸ By abandoning the creation of a custom dataset and instead utilizing OASB and AgentDojo to test the local MCP setup, the methodological rigor of the paper increases exponentially while saving months of manual development time. The software engineering requirements are highly manageable. Building mock MCP servers using the official Python SDK or the FastMCP library is technically straightforward.³ Containerizing the environment via Docker ensures that simulated directory traversal or arbitrary code execution attacks do not permanently damage the host machine.³ The primary difficulty will lie in orchestrating the communication between the local LLM, the Docker container, and the benchmark evaluation scripts, requiring strong intermediate Python skills. The overall feasibility of this project is rated at 7.5 out of 10. The estimated difficulty level is High, not due to hardware costs, but because of the complex integration of local LLMs, Docker sandboxing, and strict protocol adherence. The minimum resources required are simply a modern laptop, open-source software, and a stable internet connection. The work can absolutely be completed using only free-tier tools, provided the methodology strictly accounts for the cognitive constraints of local 8B parameter models.

Publication Potential

The probability of this research translating into a published journal article is highly contingent on the framing of the contribution and the rigorous selection of the target venue. Given the constraints, the project must avoid conferences and target indexed journals.

This study is best framed as an Experimental Security Paper. It moves beyond the theoretical warnings of architectural vulnerabilities by providing quantitative metrics on how easily open-weight models succumb to privilege aggregation through standardized protocols like MCP.³ Because the research uses low-parameter models due to budget constraints, this limitation must be explicitly positioned as a core feature of the study. Reviewers at top journals may question why state-of-the-art proprietary models were not evaluated. The manuscript must proactively argue that as agentic architectures push toward edge computing and local-first execution to preserve data privacy, understanding the unique vulnerability profiles of localized, sub-10B parameter models under MCP frameworks is a distinct, critical, and highly relevant area of study.

The topic possesses intense current research interest, fueled by high-profile industry reports on Agentjacking and MCP sampling vulnerabilities.² The primary risk to publication is desk-rejection due to a perceived lack of scale. This can be mitigated through exceptional methodological rigor, transparent statistical reporting, and the use of recognized benchmarks like OASB.⁹

Acceptance probabilities vary significantly by journal tier. For top-tier journals (Q1, high impact factor), the estimated acceptance probability is between 15% and 25%. These venues expect massive empirical scale, novel defensive architectures with mathematical proofs, or evaluations across both proprietary and open-source models, making them highly ambitious for a constrained undergraduate project. For mid-tier indexed journals (Q2/Q3, Scopus/ESCI) with a specific security focus, the probability rises to 55% - 70%. These journals are highly receptive

to novel proof-of-concept evaluations of emerging technologies, and the combination of MCP, Agentjacking concepts, and rigorous empirical measurement strongly aligns with their editorial appetites. For low-tier indexed journals (Q4, Scopus), the probability exceeds 85%, provided the methodology is sound and the writing adheres to academic standards. The overall publication potential score stands at 8.0 out of 10.

Target Journal Mapping

To align with the constraints of no physical presentation, zero publication costs, and realistic undergraduate targets, the publication strategy must exclusively target journals operating under a Hybrid Open Access model. In these models, authors can choose to publish their work behind a paywall (the traditional subscription model) at absolutely no cost, bypassing the high Article Processing Charges (APCs) typical of Gold Open Access journals.⁵ The evaluation of institutional indexing standards, such as the requirement for Scopus or Web of Science (SCIE/ESCI) inclusion, ensures the publication will carry academic weight.²¹

The following mapping categorizes suitable journals based on their alignment with the project's scope, indexing status, and realistic probability of acceptance.

Ambitious Targets (High Prestige, High Difficulty)

Journal Name	Publisher	Indexing	Rank / APC	Match & Difficulty
Computers & Security	Elsevier	Scopus, SCIE	Q1. Hybrid (Subscription is free). ²³	Excellent Match. Focuses on theoretical and practical aspects of technology-related security. ²⁶ Review Difficulty: High. Requires exceptionally rigorous empirical validation. ²⁷ Estimated acceptance: ~20%.

IEEE Transactions on Dependable and Secure Computing	IEEE	Scopus, SCIE	Q1. Hybrid (Subscription is free).	Excellent Match. Strong focus on the architectural boundaries of systems. ²⁶ Review Difficulty: Very High. Demands robust mathematical and architectural proofs. Estimated acceptance: ~10%.
---	------	--------------	------------------------------------	--

Realistic Targets (Optimal Balance of Prestige and Attainability)

Journal Name	Publisher	Indexing	Rank / APC	Match & Difficulty
Journal of Information Security and Applications (JISA)	Elsevier	Scopus, SCIE	Q1/Q2. Hybrid (Subscription is free). ⁷	Perfect Match. Bridges academia and industry, focusing on practice-driven applications. ³¹ Review Difficulty: Moderate-High. Very fast first decision (~3 weeks), ideal for

				undergrad timelines. ³¹ Estimated acceptance: ~50%.
Journal of Cyber Security Technology	Taylor & Francis	Scopus, ESCI	Q2. Hybrid (Subscription is free). ⁶	Very Strong Match. Encourages submissions on embedded systems and threat detection. ³³ Review Difficulty: Moderate-High. Fast first decision (3 days) but long post-review (49 days). ⁶ Estimated acceptance: ~40%.

Backup Targets (High Probability of Acceptance)

Journal Name	Publisher	Indexing	Rank / APC	Match & Difficulty
Security and Privacy	Wiley	Scopus, ESCI	Q2/Q3. Hybrid (Subscription is free). ³⁴	Good Match. Broad focus on security technologies and network security. ²⁸ Review Difficulty: Moderate.

				Rapid publication metrics (first decision ~21 days). ³⁴ Estimated acceptance: ~65%.
International Journal of Information and Computer Security	Inderscience	Scopus	Q4. Hybrid (Subscription is free). ²⁷	Good Match. Aligns with AI in security and software vulnerabilities. ² ⁷ Review Difficulty: Low-Moderate. Warning: Known for sluggish review processes. ³⁸ Estimated acceptance: ~75%.

Avoid List

Certain journals must be strictly avoided due to misalignment with the project constraints. The *Information Security Journal: A Global Perspective* (Taylor & Francis), while a reputable hybrid journal, suffers from excruciatingly long review times, averaging 230 days from submission to first decision, which would severely compromise any undergraduate timeline.⁵ Additionally, any journal that mandates an APC without offering a traditional subscription route (e.g., Gold Open Access only venues) must be avoided to adhere to the zero-cost constraint. Finally, predatory venues or those offering "fast-track review" for arbitrary fees must be shunned, as they damage academic credibility.³⁹

Quantitative Evaluation Matrix

The strategic viability of the revised research proposal is quantified across ten critical dimensions, reflecting the strict constraints of an undergraduate researcher operating with zero funding.

Metric	Score /10	Reason for Score
--------	-----------	------------------

Novelty	9.0	Privilege aggregation and transitive trust via MCP is highly contemporary. It moves far beyond saturated basic chatbot prompt injection into structural system flaws.
Feasibility	7.5	Technically demanding but completely feasible using local Docker containers and Python. The primary challenge is relying on the complex reasoning capabilities of small LLMs.
Dataset Availability	8.5	Extremely high, provided the methodology pivots away from custom data synthesis to leverage established, open-source frameworks like OASB and AgentDojo.
Compute Affordability	9.5	The entire experimental pipeline can be executed locally via Ollama using quantized 8B parameter models, reducing cloud API and hardware costs to exactly \$0.
Methodological Strength	8.0	Utilizing quantitative metrics (ASR, TID) against standardized benchmarks establishes a clear, rigorous empirical baseline for evaluating cognitive security vulnerabilities.

Publication Potential	8.0	The topic aligns perfectly with current editorial interests in mid-tier cybersecurity journals, provided the scope limitations regarding model size are clearly addressed.
Undergraduate Suitability	7.0	Requires a steep learning curve integrating LLMs, JSON-RPC, and Docker sandboxing, but yields exceptionally high educational and professional portfolio value.
Time-to-Completion	7.0	Integrating pre-existing benchmarks makes a 6-month completion highly realistic. Attempting to build the infrastructure from scratch would make the timeline impossible.
Risk Level (Inverted)	6.5	Medium risk. The primary danger remains that a local 8B model fails to understand the MCP protocol intrinsically, thereby ruining the attack simulations through sheer incompetence.
Journal Fit	9.0	"Hybrid" publishing models at major publishers (Elsevier, Wiley, Taylor & Francis) allow for high-quality, indexed, zero-cost publication.

The synthesis of these metrics yields an **Overall Research Viability Score of 80 out of 100**. The risk-adjusted publication probability is estimated at **65%**, assuming the researcher targets a well-matched mid-tier Q2/Q3 journal such as the *Journal of Information Security and Applications* or Wiley's *Security and Privacy*. The final confidence level in this recommendation is **High**. The transition from a theoretical multi-agent conference paper to a highly focused empirical evaluation utilizing local models and standardized benchmarks makes this project highly viable.

Challenges and Mitigations

An undergraduate attempting to publish advanced AI security research faces several critical barriers. Identifying these challenges early allows for the implementation of structured, realistic mitigations that align with the project's zero-cost constraints.

The most critical risk is the compute and cognitive bottleneck. The research relies on exposing a language model to multiple MCP tools and tricking it into chaining them maliciously.³

However, small local models (e.g., standard Llama-3-8B) often lack the cognitive reasoning required to consistently output perfectly formatted JSON-RPC tool calls. If the baseline failure rate is high, the adversarial failure rate becomes statistically meaningless. Reviewers will reject the paper if the empirical data is skewed by the model's inherent incompetence rather than the effectiveness of the security mitigations. The mitigation strategy is to avoid general-purpose chat models. The researcher must deploy specialized, quantized local models explicitly fine-tuned for tool calling, such as Hermes-2-Pro or Qwen-2.5-Coder. The baseline evaluation must formally prove that the model achieves greater than 90% accuracy on benign tool execution before any attacks are introduced. This mitigation is entirely realistic, as these models are free and fit within 16GB of unified memory.

Dataset and evaluation risks are also highly significant. The original proposal advocates for synthesizing a custom evaluation dataset comprising various injection payloads and mock tools.³ Building a statistically significant dataset of prompts, tools, and expected outcomes takes months, and custom datasets are heavily scrutinized by reviewers for bias. The mitigation is to abandon the custom dataset completely. Instead, the research must utilize the Open Agent Security Benchmark (OASB) or the AgentDojo dynamic environment.⁸ These frameworks already contain hundreds of peer-reviewed security test cases, including specific payloads for MCP exploitation and tool-chaining.⁸ This pivot is highly realistic, as both frameworks are open-source and free to use.

The rapid evolution of the AI ecosystem presents a medium-level novelty risk. The Model Context Protocol is evolving quickly, and by the time this paper is submitted, underlying specifications may have changed, or official patches may have been released. The research could be deemed obsolete before it completes peer review. To mitigate this, the researcher must freeze all dependency versions locally using strict Docker images. More importantly, the paper must frame the vulnerability not as a transient software bug, but as a fundamental architectural flaw in how autoregressive models process interleaved semantic data and control instructions—the "Lethal Trifecta" concept.⁴ Protocol updates cannot easily resolve this

inherent cognitive conflation. This framing protects the research from software obsolescence and requires only careful academic writing.

Reviewer expectation risk is consistently high for constrained researchers. Reviewers at reputable security journals are accustomed to empirical studies backed by massive compute budgets, evaluating thousands of prompts across state-of-the-art proprietary models. The paper risks rejection for having too narrow a scope. To mitigate this, the researcher must proactively lean into the hardware constraints in the methodology section. The study should be framed specifically around the security of "Edge-Deployed, Privacy-Preserving Agentic Systems." The argument must be made that as enterprises mandate local-only AI deployments to protect intellectual property, understanding the unique privilege aggregation vulnerabilities of open-weight, sub-10B parameter models is an independent and vital research domain. This narrative positioning is realistic and costs nothing.

Finally, writing quality and reproducibility risks can sink otherwise excellent data.

Undergraduate papers often read like project reports rather than scientific literature, leading to immediate desk rejections. Furthermore, if the local environment is not strictly controlled, the results cannot be replicated. The mitigation strategy involves strictly adopting standard academic structures, using LaTeX for formatting, and presenting all metrics in clean tables with appropriate statistical significance markers. Reproducibility must be guaranteed by publishing the Dockerfiles and fixing random seeds during inference. These practices are standard in the field and require only discipline to execute.

Challenge Domain	Severity	Why it Matters	Mitigation Strategy	Realistic?
Compute / Baseline	Critical	Small models failing JSON-RPC formatting invalidate the attack metrics.	Use tool-optimized quantized models (e.g., Hermes-2-Pro) and establish a >90% benign success baseline.	Yes. Runs on standard 16GB laptops.
Dataset / Evaluation	High	Custom datasets take months to build and are scrutinized for bias.	Adopt open-source benchmarks like OASB or AgentDojo instead of synthesizing custom	Yes. Both frameworks are free and available.

			payloads.	
Reviewer Expectations	High	Reviewers may demand proprietary model evaluations (e.g., GPT-4o).	Frame the research explicitly around the security of "Edge-Deployed, Privacy-Preserving Agentic Systems."	Yes. Requires strategic academic writing.
Novelty / Ecosystem	Medium	The MCP standard may update before the paper is published.	Frame the issue as an architectural flaw (Lethal Trifecta), not a transient software bug. Freeze dependencies.	Yes. Requires careful narrative positioning.
Writing / Formatting	Medium	"Project report" tone leads to immediate editorial desk rejections.	Use LaTeX, formal academic prose, clear statistical tables, and heavily cite theoretical literature.	Yes. Free tools like Overleaf are available.

What Would Make This Paper Stronger

To elevate this research from a promising student project to a robust, Q1/Q2 journal-quality publication, several strategic enhancements should be integrated into the core design without increasing the financial or hardware burden.

First, the research angle must be sharpened significantly. Instead of attempting to prove that MCP is generally insecure, the paper should focus intensely on the cognitive mechanics of

privilege aggregation. The research should seek to answer a specific, measurable question: *At what threshold of tool exposure does a local LLM transition from being a secure, isolated processor to a critical system vulnerability?* By evaluating the Attack Success Rate (ASR) when an agent has access to one tool, versus two tools, versus five tools, the researcher can mathematically model the risk of capability scaling. This transforms the paper from a simple hacking demonstration into a formal, quantitative study of AI system dynamics under stress. Second, the paper must implement a deterministic baseline comparison. Peer reviewers will expect to see proposed solutions evaluated alongside the vulnerability disclosures. The original proposal mentions a vague "Security Shield".³ To make this academically rigorous, the defense should be framed around the concept of "Deterministic Reference Monitors," as theorized in the literature.⁴ The study should present empirical results demonstrating the agent's behavior across three distinct states: under attack with no defenses (yielding a high ASR), under attack with an LLM-based "system prompt" defense (demonstrating that prompt alignment is insufficient), and under attack with a deterministic, programmatic reference monitor (demonstrating that the attack is blocked while benign utility is preserved). This comparative analysis is highly valued in security literature. Third, the framing of the paper must be highly objective. It should not be written as a critique of Anthropic or the MCP standard. Instead, it should be framed as an exploration of the fundamental friction between deterministic computer systems (which require strict boundaries) and probabilistic cognitive engines (which process all text uniformly). The Model Context Protocol should be presented as the necessary and brilliant catalyst that has simply brought this underlying architectural friction to the surface. This objective, structural tone is highly favored by journal editors and reviewers. Finally, to convince reviewers, the manuscript must contain specific, undeniable evidence. This includes a clearly defined Threat Model adapting frameworks like STRIDE to the local-MCP environment, transparent baseline metrics proving the 8B parameter model's competence, and quantitative charts showing how ASR changes based on the injection technique. By mirroring real-world threat models like Agentjacking (e.g., indirect markdown injection via simulated error logs)¹⁶, the research bridges the gap between academic theory and practical enterprise security, making it a highly compelling contribution.

Final Recommendation

Based on the exhaustive analysis of the constraints, the literature, and the publishing landscape, the final recommendation is clear.

Should I start this research title or not?

You should **START** this research, but you must **REVISE** the methodology and the title immediately. The core concept is highly publishable, intensely relevant to current industry challenges (such as Agentjacking), and technically feasible on a zero-budget setup. However, the original project design is too broad and unaligned with the realities of undergraduate hardware and journal-specific expectations.

What is the best version of the title?

The optimal title is: *"Evaluating Privilege Aggregation Vulnerabilities in Edge-Deployed AI Agents: An Empirical Analysis of the Model Context Protocol."* This title is superior because it

specifies the constrained environment (Edge-Deployed, justifying the use of local small models), identifies the exact vulnerability (Privilege Aggregation), and clearly states the methodological approach (Empirical Analysis).

What is the safest publication strategy?

Submit the manuscript to the **Journal of Information Security and Applications (Elsevier)** as your primary target. You must select the traditional subscription-based publishing route during submission, which will incur absolutely \$0 in APCs while allowing your work to be indexed in Scopus and Web of Science (SCIE). Their fast initial review time (approximately 3 weeks) is highly favorable for an undergraduate timeline. If rejected or if revisions are too demanding, cascade the submission to **Security and Privacy (Wiley)** as a reliable Q2/Q3 backup.

What is the estimated probability of publication if executed well?

If you successfully integrate established benchmarks (OASB or AgentDojo), utilize a tool-optimized local model (e.g., Hermes-2-Pro), and follow rigorous academic formatting, the risk-adjusted probability of publication in a mid-tier indexed journal is estimated at **65% to 75%**.

What should be my next steps?

1. **Freeze the Scope:** Abandon the "Transitive Trust" aspect for now; focus entirely on measuring how exposing multiple tools increases exploitability (Privilege Aggregation).
2. **Environment Setup:** Install Docker and Ollama. Pull a tool-calling optimized 8B model (do not use a generic chat model).
3. **Benchmark Integration:** Clone the Open Agent Security Benchmark (OASB) repository and understand how its evaluation scripts interface with an agent.
4. **Baseline Testing:** Before writing any attack payloads, ensure your local agent can successfully orchestrate a multi-step task using 3-4 benign mock tools via FastMCP. If the model cannot do this reliably without attacks, you must tune the system prompt or switch models until the baseline is stable. Only then should you introduce the adversarial payloads.

Works cited

1. Prompt Injection Attacks on Agentic Coding Assistants: A ... - arXiv, accessed June 21, 2026, <https://arxiv.org/abs/2601.17548>
2. Agentjacking: MCP Injection Hijacks AI Coding Agents, accessed June 21, 2026, https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/06/CSA_research_note_agentjacking_mcp_sentry_injection_20260612-csa-styled.pdf
3. MCP Agent Security Research Plan.pdf
4. Trustworthy Agentic AI Requires Deterministic Architectural Boundaries - arXiv, accessed June 21, 2026, <https://arxiv.org/html/2602.09947v1>
5. Learn about Information Security Journal: A Global Perspective, accessed June 21, 2026, <https://www.tandfonline.com/journals/uiss20/about-this-journal>
6. Learn about Journal of Cyber Security Technology - Taylor & Francis, accessed June 21, 2026, <https://www.tandfonline.com/journals/tsec20/about-this-journal>
7. Open Access Price List of Elsevier Journals All prices excluding taxes (date: 10-Nov-2019), accessed June 21, 2026,

- https://www.researchgate.net/publication/337820049_Open_Access_Price_List_of_Elsevier_Journals_All_prices_excluding_taxes_date_10-Nov-2019
8. AgentDojo Open Project – Comprehensive Analysis of an LLM Agent Training & Evaluation Framework - Ghost, accessed June 21, 2026, <https://storage.ghost.io/c/08/98/0898c867-a7cb-42b3-b4bc-d3067194bdf8/content/files/2026/01/AgentDojo-report.pdf?ref=thaiaiaudit.com>
 9. OASB – Open Agent Security Benchmark | Security Standard for AI Agents, accessed June 21, 2026, <https://oasb.ai/>
 10. Artificial Intelligence Security Issues: Coding Agent Risks | Fiddler AI Blog, accessed June 21, 2026, <https://www.fiddler.ai/blog/artificial-intelligence-security-issues>
 11. Model Context Protocol Threat Modeling and Analyzing Vulnerabilities to Prompt Injection with Tool Poisoning - arXiv, accessed June 21, 2026, <https://arxiv.org/pdf/2603.22489>
 12. Model Context Protocol Threat Modeling and Analysis of Vulnerabilities to Prompt Injection with Tool Poisoning - MDPI, accessed June 21, 2026, <https://www.mdpi.com/2624-800X/6/3/84>
 13. [2602.09947] Trustworthy Agentic AI Requires Deterministic Architectural Boundaries - arXiv, accessed June 21, 2026, <https://arxiv.org/abs/2602.09947>
 14. New Prompt Injection Attack Vectors Through MCP Sampling, accessed June 21, 2026, <https://unit42.paloaltonetworks.com/model-context-protocol-attack-vectors/>
 15. Agentjacking: MCP Injection Hijacks AI Coding Agents - Lab Space, accessed June 21, 2026, <https://labs.cloudsecurityalliance.org/research/csa-research-note-agentjacking-mcp-sentry-injection-20260612/>
 16. Preempting Agentjacking: Validating MCP Trust Boundaries in AI Workflows - Saptang Labs, accessed June 21, 2026, <https://saptanglabs.com/preempting-agentjacking-validating-mcp-trust-boundaries-in-ai-workflows/>
 17. Prompt Injection Attacks on Agentic Coding Assistants: A Systematic Analysis of Vulnerabilities in Skills, Tools, and Protocol Ecosystems - arXiv, accessed June 21, 2026, <https://arxiv.org/pdf/2601.17548>
 18. A Systematic Security Analysis of Model Context Protocol: Vulnerabilities, Exploits, and Mitigations | Request PDF - ResearchGate, accessed June 21, 2026, https://www.researchgate.net/publication/401127547_A_Systematic_Security_Analysis_of_Model_Context_Protocol_Vulnerabilities_Exploits_and_Mitigations
 19. anmolksachan/AI-ML-Free-Resources-for-Security-and-Prompt-Injection: AI/ML Pentesting Roadmap for Beginners - GitHub, accessed June 21, 2026, <https://github.com/anmolksachan/AI-ML-Free-Resources-for-Security-and-Prompt-Injection>
 20. Updates | OASB | OASB - AI Agent Security Benchmark, accessed June 21, 2026, <https://oasb.ai/updates>
 21. Background Objective HEC Journal Recognition System - IoBM Research Office, accessed June 21, 2026,

<https://iro.iobm.edu.pk/wp-content/uploads/2023/08/HEC-Journal-Recognition-System.pdf>

22. Prevailing Predatory Publishing: A Critical Evaluation of Publications from Pakistan's Physical Education and Sport Science Domains - ResearchGate, accessed June 21, 2026,
https://www.researchgate.net/publication/385227065_Prevailing_Predatory_Publishing_A_Critical_Evaluation_of_Publications_from_Pakistan's_Physical_Education_and_Sport_Science_Domains
23. Elsevier Subscription Agreement of 01 January 2024 by and between Consortium of Swiss Academic Libraries c/o SLSP AG, accessed June 21, 2026,
https://consortium.ch/wp_live/wp-content/uploads/2024/06/Elsevier_Journals_agreement_2024-2028.pdf
24. Elsevier Subscription Agreement - California Digital Library, accessed June 21, 2026,
https://cdlib.org/services-groups/collections/licensed_resources/redacted_licenses/STEElsevierSD_2014-2018_Redacted.pdf
25. Fast publish Scopus Indexed Journals 2025 For Computer Science, accessed June 21, 2026,
<https://networksimulationtools.com/scopus-indexed-journals-2025-for-computer-science/>
26. List Of Scopus Indexed Journals 2025 For Computer Science | NS2 Project, accessed June 21, 2026,
<https://www.ns2project.com/list-of-scopus-indexed-journals-2025-for-computer-science/>
27. Cybersecurity Journal Acceptance Rates | PDF | Open Access | Computer Security - Scribd, accessed June 21, 2026,
<https://www.scribd.com/document/897749596/table>
28. Editorial - IEEE Computer Society, accessed June 21, 2026,
<https://www.computer.org/csdl/journal/tq/2019/01/08613033/17D45Vw15wV>
29. Journal of Information Security and Applications Impact Factor (2025), accessed June 21, 2026,
<https://www.journalmetrics.org/journal/journal-of-information-security-and-applications>
30. Journal Of Information Security And Applications impact factor, indexing, ranking (2026), accessed June 21, 2026,
<https://journalsearches.com/journal.php?title=journal%20of%20information%20security%20and%20applications>
31. Journals in Physical sciences and engineering - Elsevier, accessed June 21, 2026,
<https://shop.elsevier.com/journals/subjects/physical-sciences-and-engineering>
32. Journal Of Cyber Security Technology impact factor, indexing, ranking (2026), accessed June 21, 2026,
<https://journalsearches.com/journal.php?title=journal%20of%20cyber%20security%20technology>
33. Journal of Cyber Security Technology - Taylor and Francis Ltd | 2024 Cite Score: 5.5 | Q2, accessed June 21, 2026,

- <https://slogix.in/research/journals/journal-of-cyber-security-technology-taylor-and-francis-ltd-%7C-2024-cite-score-5.5-%7C-q2/>
34. Information | An Open Access Journal from MDPI, accessed June 21, 2026, https://www.mdpi.com/journal/information?n1=9&utm_from=3a1f553a47
 35. Security and Privacy Impact Factor (2025): 2.1, Q3, Trend & Similar Journals, accessed June 21, 2026, <https://www.journalmetrics.org/journal/security-and-privacy>
 36. Included - DHBW Mannheim, accessed June 21, 2026, https://www.mannheim.dhbw.de/fileadmin/user_upload/Services/Bibliothek/20210825-Wiley-Zeitschriftentitel-2019-2021-Bibliothek-DHBW-Mannheim.xlsx
 37. international journal of information and computer security Impact Factor, Ranking, publication fee, indexing, accessed June 21, 2026, <https://journalsearches.com/journal.php?title=international%20journal%20of%20information%20and%20computer%20security>
 38. How long does it typically take for the first decision on a manuscript submitted to the Inderscience Journal? | ResearchGate, accessed June 21, 2026, https://www.researchgate.net/post/How_long_does_it_typically_take_for_the_first_decision_on_a_manuscript_submitted_to_the_Inderscience_Journal
 39. Information Security Journals - Department of Computer Science, accessed June 21, 2026, <https://www.cs.sjsu.edu/~stamp/securityJournals.html>
 40. Information Security Journals :: The good, the bad, and the ugly - K K Patel, accessed June 21, 2026, <https://kkpatel7.wordpress.com/2014/03/27/information-security-journals-the-good-the-bad-and-the-ugly/>
 41. OASB - opena2a-org/open-agent-security-benchmark - GitHub, accessed June 21, 2026, <https://github.com/opena2a-org/oasb>